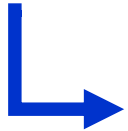




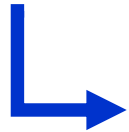
РБПО ПРЕДПРИЯТИЙ ТОПЛИВНОГО ДИВИЗИОНА

Ключевая цель – определить подход, позволяющий обеспечить эффективную защиту предприятий Топливного дивизиона от рисков, связанных с разработкой и эксплуатацией программного обеспечения

Увеличение числа инцидентов, связанных с разработкой ПО (громкие внешние инциденты и выявленные внутренние на предприятиях)



Усиление требований регуляторов в части разработки ПО (приказы и связанные методики ФСТЭК, ГОСТ 56939-2024)



Необходимость единого подхода обеспечения безопасности процесса разработки ПО

3.1 **безопасное программное обеспечение**: Программное обеспечение, разработанное в ходе реализации совокупности процессов (мер), направленных на предотвращение появления и устранение недостатков программы

4.1 Основной **целью разработки безопасного ПО** является:

- выявление недостатков, в том числе уязвимостей, в разрабатываемом ПО;
- снижение количества недостатков, в том числе уязвимостей ПО;
- снижение ущерба от невыявленных уязвимостей ПО;
- оперативное устранение выявляемых уязвимостей в ПО

4.13 **При разработке ПО** средой разработки ПО должны быть обеспечены контроль версий разрабатываемого ПО, непрерывная интеграция разрабатываемого ПО, управление задачами, в том числе по отслеживанию ошибок в коде ПО. **Процессы разработки безопасного ПО необходимо интегрировать с применяемыми в среде разработки ПО системами** в целях обеспечения регулярности и своевременности проверок кода, прослеживаемости устранения выявленных ошибок.

4.14 ... В случае, **когда в соответствующих документах определена необходимость соответствия настоящему стандарту, обязательной реализации подлежат все требования стандарта**, за исключением рекомендуемых к реализации требований, в формулировках таких требований используются вспомогательные глаголы «рекомендуется» и «может»

КСПД: РБПО (ГОСТ 56939-2024) И ИНСТРУМЕНТЫ



5.1 – 5.3,
5.6

5.7 – 5.8

5.14 – 5.15

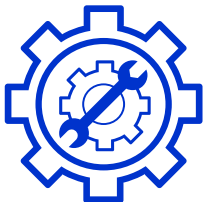
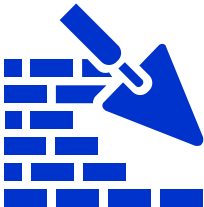
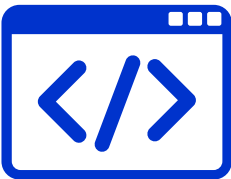
5.12 – 5.13,
5.16

5.9 – 5.11,
5.17 – 5.19

5.20 – 5.21

5.22 – 5.25

5.4 – 5.5



Сбор требований

Проектирование

Разработка

Сборка

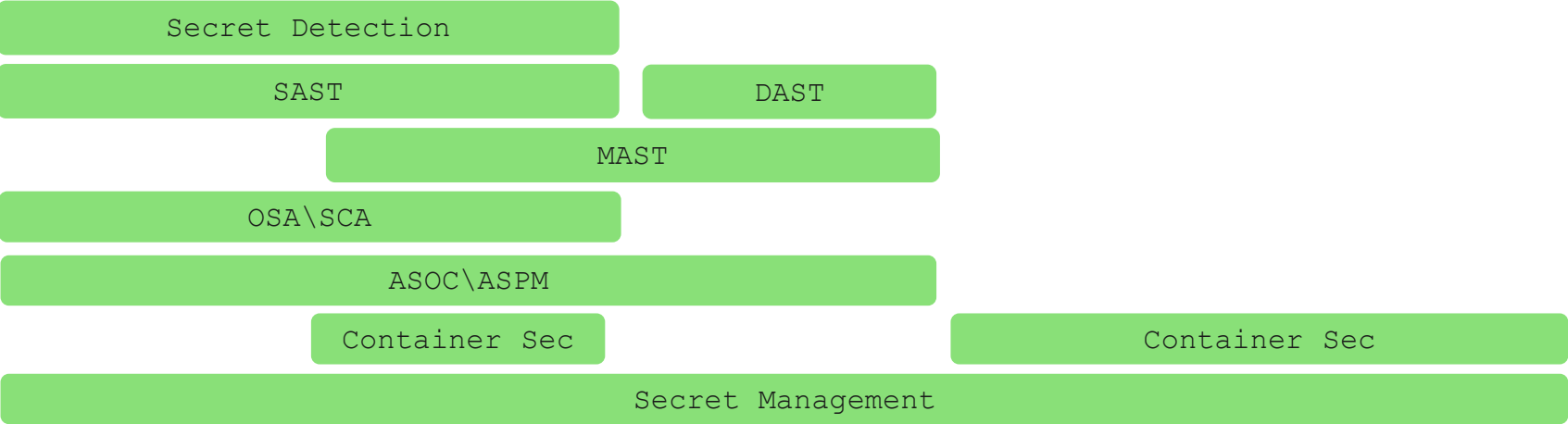
Тестирование

Развертывание

Эксплуатация

База знаний + отслеживание задач

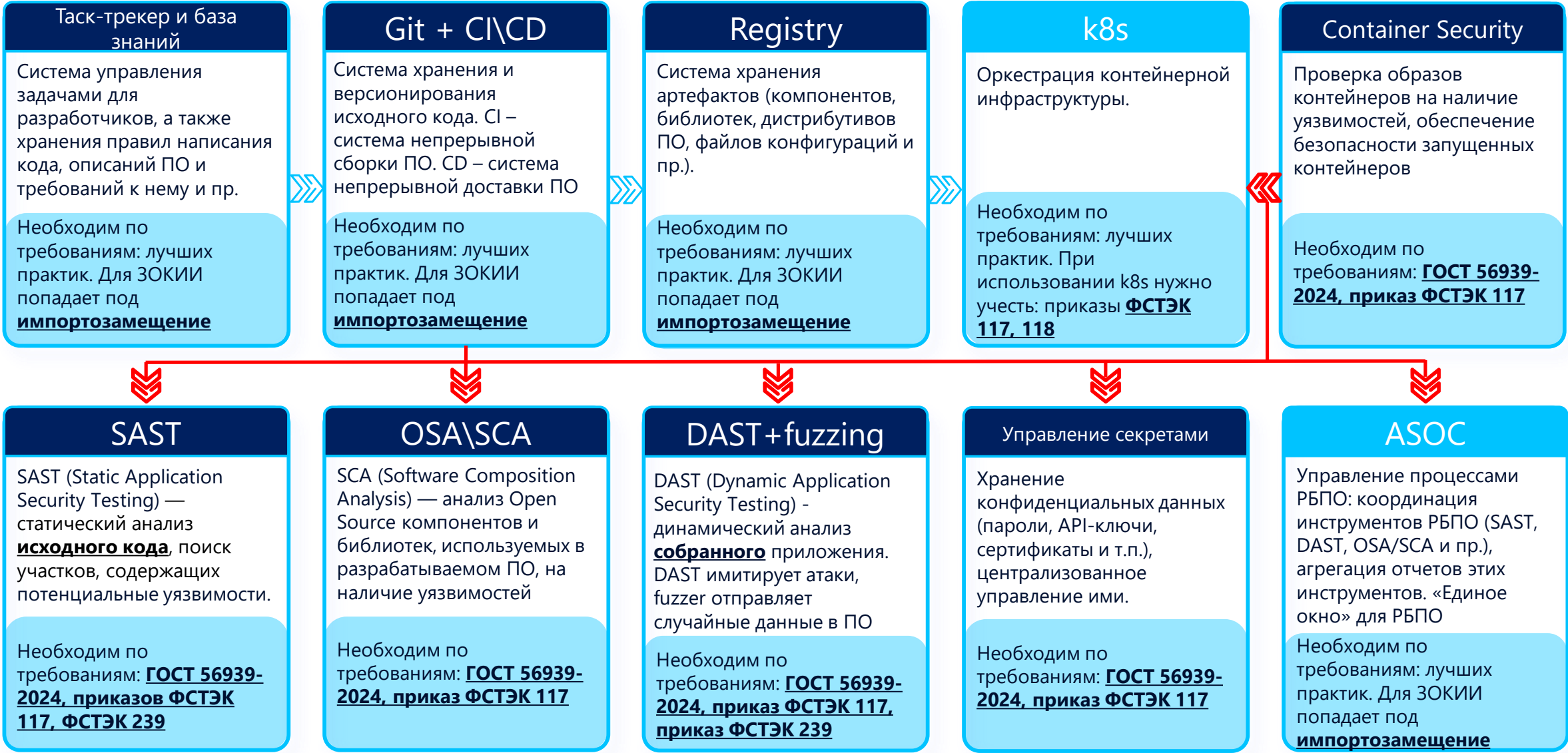
Система версионирования кода + Система сборки + Система хранения артефактов + Контейнерная инфраструктура



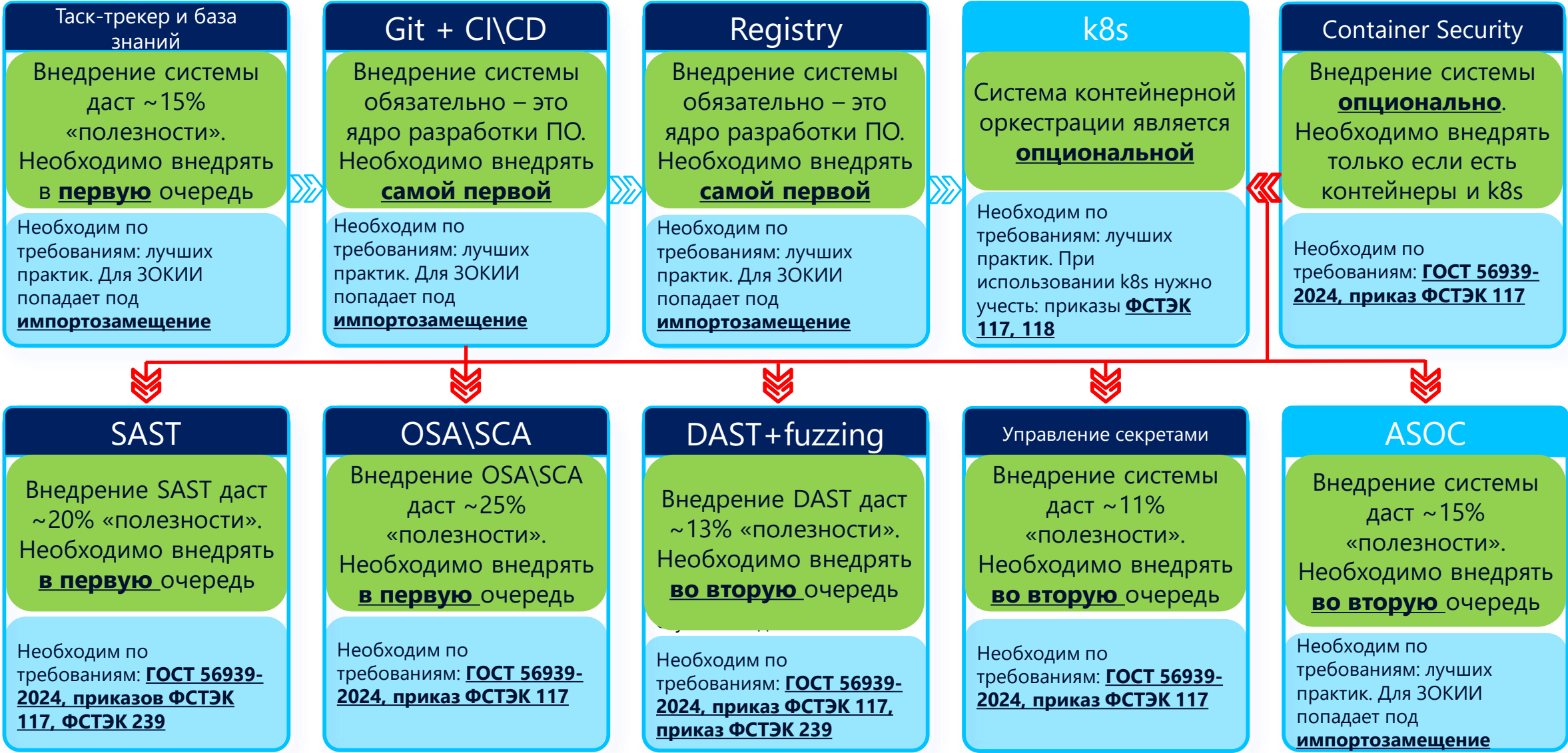
КСПД: ТИПОВАЯ РАЗРАБОТКА ПО И ИНСТРУМЕНТЫ



КСПД: ТРЕБОВАНИЯ РБПО (ГОСТ 56939-2024) И ИНСТРУМЕНТЫ



КСПД: ПРИОРИТЕТЫ И ЭФФЕКТЫ ОТ РБПО



ТСПД: РБПО (ГОСТ 56939-2024) И ИНСТРУМЕНТЫ



* На рынке отсутствуют программные инструменты проверки ПО, поддерживающие языки и среды разработки ПО АСУ ТП. Основной объем требований ГОСТ закрывается орг. мерами, ОРД, проверками кода в «ручном режиме»

ТСПД: ДОСТУПНЫЕ ИНСТРУМЕНТЫ РБПО В АСУ ТП

Реализация процесса РБПО

Таск-трекер и база знаний

Система управления задачами для разработчиков, а также хранения правил написания кода, описаний ПО и требований к нему и пр.

Система хранения ПО

Выделение системы хранения данных для АСУ ТП для хранения разработанного ПО. Разрабатывается регламент хранения и наименования версий ПО. Должны быть реализованы технические и организационные меры защиты самой системы хранения данных.

Контроль целостности

В составе системы хранения должен быть реализован механизм контроля целостности с применением наложенных средств защиты. Также эта функция предусмотрена в составе некоторых сред разработки ПЛК.

Управление секретами

Хранение конфиденциальных данных (пароли, API-ключи, сертификаты и т.п.).

Должно быть описано соответствующим регламентом. Для хранения должны быть реализованы технические и организационные меры.

Проверки кода

Экспертиза кода

Не предусматривает реального выполнения кода. Подразумевает вычитку и анализ написанного кода ПО экспертом. Должна выполняться специалистом, не участвовавшим в разработке.

Функциональное тестирование

Вид работ по исследованию программы, направленный на выявление отличий между ее реально существующими и требуемыми свойствами. По сути проверка — это проверка недекларированных возможностей.

Проводится на эмуляторах SCADA и ПЛК.

Нефункциональное тестирование

Под нефункциональным тестированием понимаются проверки, не относящиеся к функциональному, то есть подача на вход программы не предусмотренных алгоритмом воздействий, контроль реакции программы.

Проводится на эмуляторах SCADA и ПЛК.

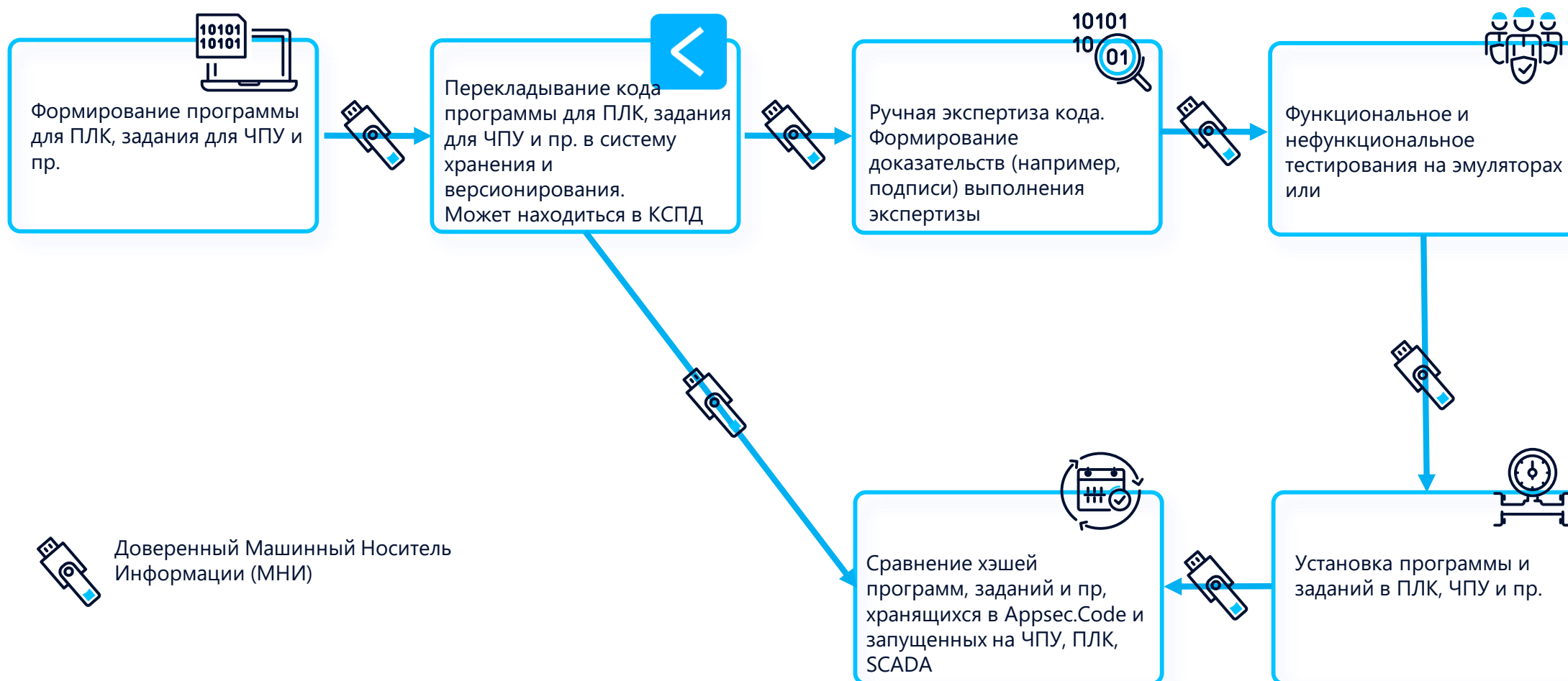
ТСПД: ДОСТУПНЫЕ ИНСТРУМЕНТЫ РБПО В АСУ ТП

Реализация процесса РБПО	Таск-трекер и база знаний Система управления задачами для разработчиков, а также хранения правил написания кода, описаний ПО и требований к нему и пр.	Система хранения ПО Выделение системы хранения данных для АСУ ТП для хранения разработанного ПО. Разрабатывается регламент хранения и наименования версий ПО. Должны быть реализованы технические и организационные меры защиты самой системы хранения данных.	Контроль целостности В составе системы хранения должен быть реализован механизм контроля целостности с применением наложенных средств защиты. Также эта функция предусмотрена в составе некоторых сред разработки ПЛК.	Управление секретами Хранение конфиденциальных данных (пароли, API-ключи, сертификаты и т.п.). Должно быть описано... Нет секретов в АСУТП
Проверки кода	Экспертиза кода Не предусматривает реального выполнения кода. Подразумевает вычитку и анализ написанного кода ПО экспертом. Должна выполняться специалистом, не участвовавшим в разработке.	Функциональное тестирование Вид работ по исследованию программы, направленный на выявление отличий между ее реально существующими и требуемыми свойствами. По сути проверка — это проверка недекларированных возможностей. Проводится на эмуляторах SCADA и ПЛК.	Нефункциональное тестирование Под нефункциональным тестированием понимаются проверки, не относящиеся к функциональному, то есть подача на вход программы не предусмотренных алгоритмом воздействий, контроль реакции программы. Проводится на эмуляторах SCADA и ПЛК.	

ТСПД: ДОСТУПНЫЕ ИНСТРУМЕНТЫ РБПО В АСУ ТП. ПРИМЕР

Реализация процесса РБПО	Task-трекер и база знаний  Appsec.Code В Appsec.Code есть встроенный task-трекер и база знаний (wiki)	Система хранения ПО  Appsec.Code Appsec.Code может хранить внутри себя любые файлы и выполнять версионирование (время появления новых версий)	Контроль целостности  Appsec.Code Appsec.Code формирует хэши артефактов (программы, g-code и пр). Далее необходимо периодически выгружать программу из ЧПУ или ПЛК и сравнивать хэш с версией, хранящейся в Appsec.Code	Управление секретами Хранение конфиденциальных данных (пароли, API-ключи, сертификаты и т.п.). Должно быть описано Нет секретов в АСУТП
Проверки кода	Экспертиза кода  Методические рекомендации Регламентация процесса	Функциональное тестирование  Методические рекомендации Регламентация процесса	Нефункциональное тестирование  Методические рекомендации Регламентация процесса	Использование машинных носителей информации  Методические рекомендации Регламентация использования МНИ в РПБО. Формирование списка доверенных МНИ, контроль используемых МНИ

ТСПД: ДОСТУПНЫЕ ИНСТРУМЕНТЫ РБПО В АСУ ТП. ПРОЦЕСС

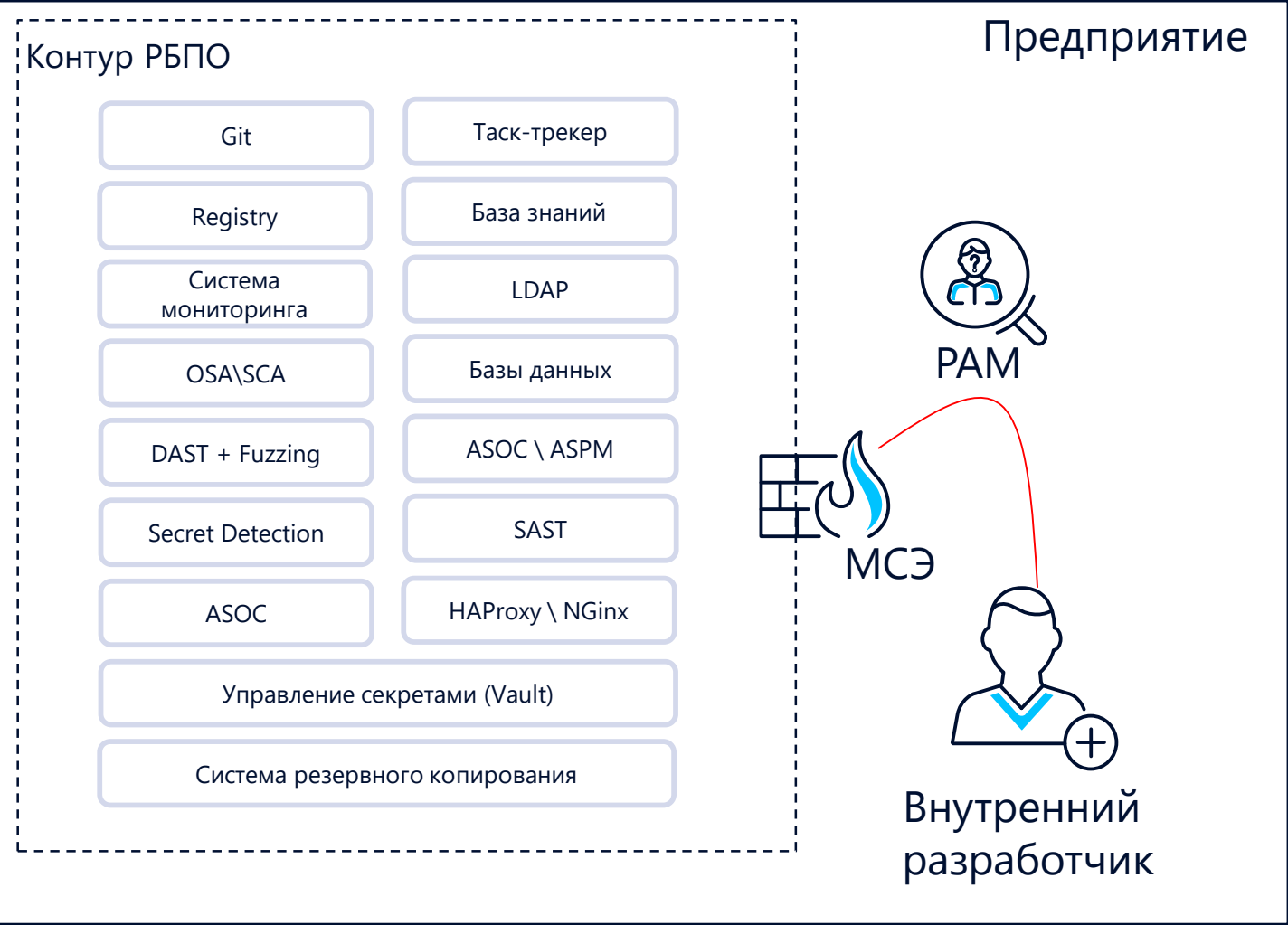


ПРИЛОЖЕНИЕ

Инфосистемы Джет



СХЕМА КОНТУРА РБПО. ОБЩИЙ ВЗГЛЯД



В части РБПО для «классической» разработки применимы все требования ГОСТ 56939-2024 и должны использоваться все инструменты анализа кода, для работы которых нужна соответствующая инфраструктура

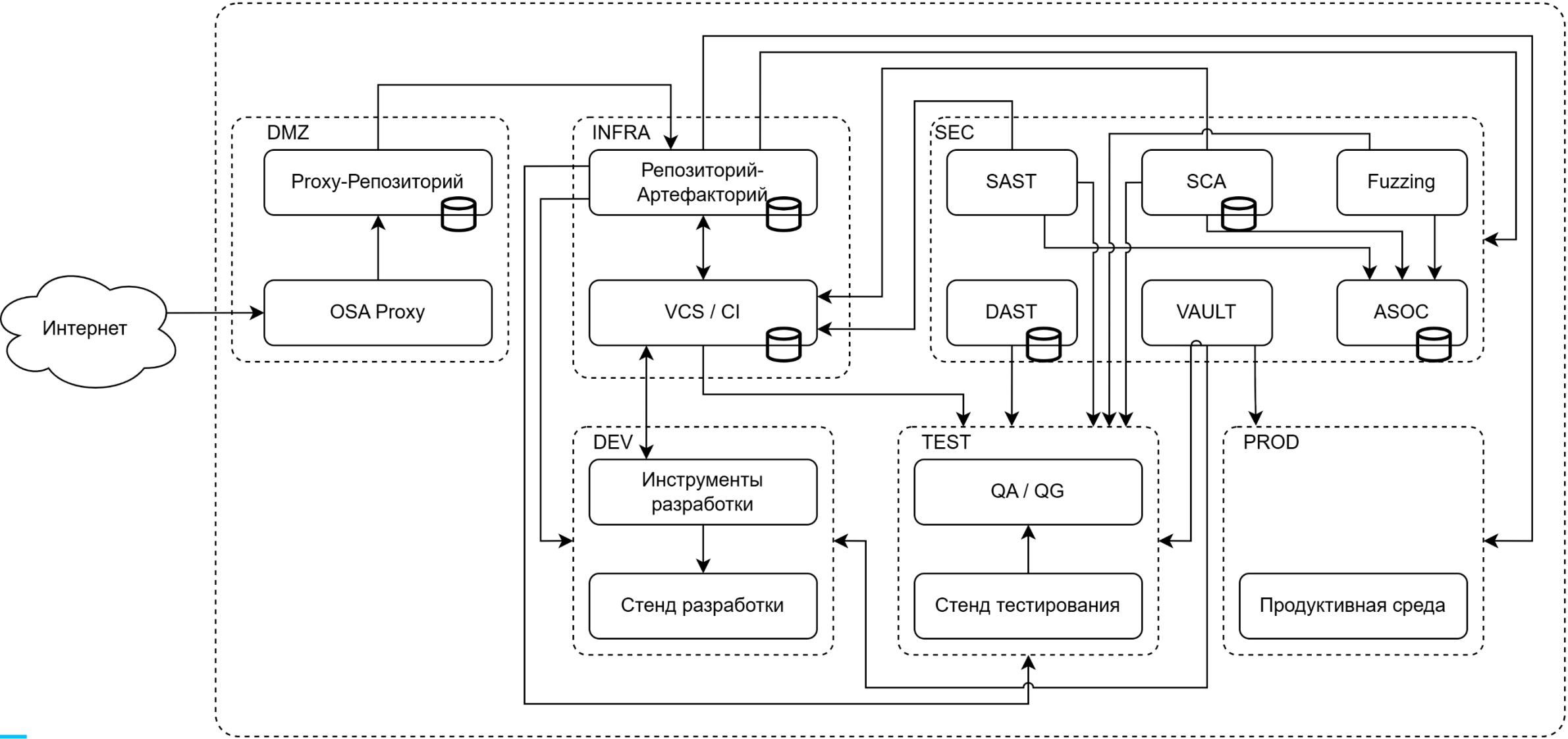
СХЕМА КОНТУРА РБПО. СЕГМЕНТЫ И ИНФРАСТРУКТУРНЫЕ РЕШЕНИЯ

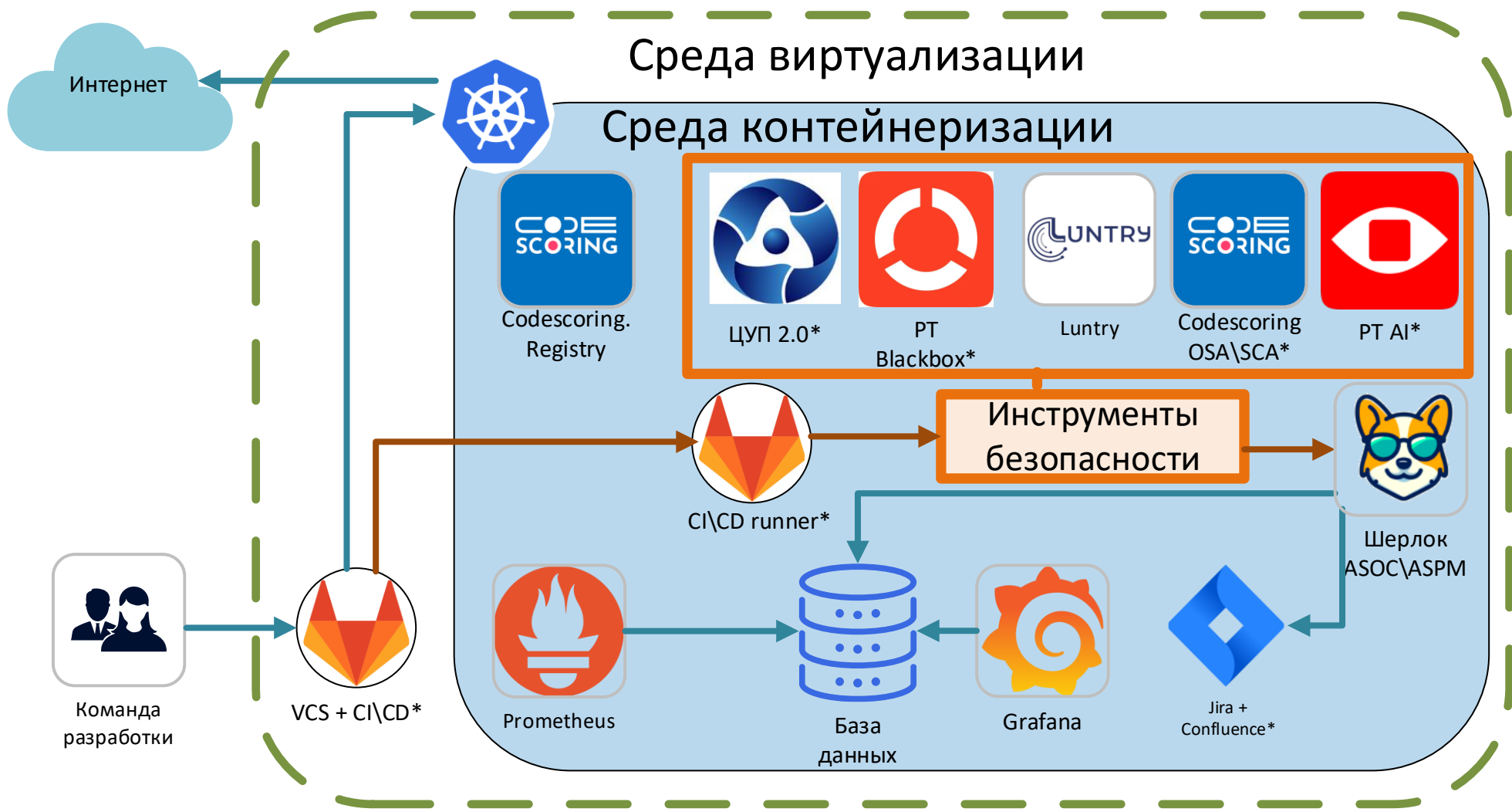


Удаленный доступ является опциональным

Достаточно **одного кластера MCЭ**. На схеме отображена логическая схема фильтрации трафика между разными сетевым зонами

СХЕМА КОНТУРА РБПО. ИНСТРУМЕНТЫ И СВЯЗИ В КОНТУРЕ РБПО





* - обязательные классы решений к внедрению. На схеме указаны конкретные инструменты, полный список инструментов каждого класса указан на следующем слайде

КСПД: ПРОЦЕССЫ РБПО (ГОСТ 56939-2024)

- 5.1 Планирование процессов разработки безопасного программного обеспечения
- 5.2 Обучение сотрудников
- 5.3 Формирование и предъявление требований безопасности к программному обеспечению
- 5.4 Управление конфигурацией программного обеспечения
- 5.5 Управление недостатками и запросами на изменение программного обеспечения
- 5.6 Разработка, уточнение и анализ архитектуры программного обеспечения
- 5.7 Моделирование угроз и разработка описания поверхности атаки
- 5.8 Формирование и поддержание в актуальном состоянии правил кодирования
- 5.9 Экспертиза исходного кода
- 5.10 Статический анализ исходного код
- 5.11 Динамический анализ кода программы
- 5.12 Использование безопасной системы сборки программного обеспечения
- 5.13 Обеспечение безопасности сборочной среды программного обеспечения
- 5.14 Управление доступом и контроль целостности кода при разработке программного обеспечения
- 5.15 Обеспечение безопасности используемых секретов
- 5.16 Использование инструментов композиционного анализа
- 5.17 Проверка кода на предмет внедрения вредоносного программного обеспечения через цепочки поставок
- 5.18 Функциональное тестирование
- 5.19 Нефункциональное тестирование
- 5.20 Обеспечение безопасности при выпуске готовой к эксплуатации версии программного обеспечения
- 5.21 Безопасная поставка программного обеспечения пользователям
- 5.22 Обеспечение поддержки программного обеспечения при эксплуатации пользователями
- 5.23 Реагирование на информацию об уязвимостях
- 5.24 Поиск уязвимостей в программном обеспечении при эксплуатации
- 5.25 Обеспечение безопасности при выводе программного обеспечения из эксплуатации

ТСПД: ПРОЦЕССЫ РБПО (ГОСТ 56939-2024)

- 5.1 Планирование процессов разработки безопасного программного обеспечения
- 5.2 Обучение сотрудников **(п.п. 5.1, 5.2 – орг. мера, реализация в рамках КСПД)**
- 5.3 Формирование и предъявление требований безопасности к программному обеспечению
- 5.4 Управление конфигурацией программного обеспечения
- 5.5 Управление недостатками и запросами на изменение программного обеспечения
- 5.6 Разработка, уточнение и анализ архитектуры программного обеспечения
- 5.7 Моделирование угроз и разработка описания поверхности атаки
- 5.8 Формирование и поддержание в актуальном состоянии правил кодирования
- 5.9 Экспертиза исходного кода **(Применимо только в ручном режиме, аналитически)**
- 5.12 Использование безопасной системы сборки программного обеспечения **(ОРД - должна быть описана система сборки, кто и как должен с ней работать)**
- 5.13 Обеспечение безопасности сборочной среды программного обеспечения **(Возможность реализовать только орг. меры)**
- 5.14 Управление доступом и контроль целостности кода при разработке программного обеспечения **(Возможность реализовать орг. меры и управление доступом встроенными механизмами ППО)**
- 5.15 Обеспечение безопасности используемых секретов **(Возможность реализовать только орг. меры)**
- 5.16 Использование инструментов композиционного анализа **(Необходимо проанализировать, применяется ли в ходе разработки заимствованный код/модули ПО, возможность реализовать только орг. меры)**
- 5.17 Проверка кода на предмет внедрения вредоносного программного обеспечения через цепочки поставок **(Необходимо проанализировать, применяется ли в ходе разработки заимствованный код/модули ПО, Возможность реализовать только орг. меры)**
- 5.18 Функциональное тестирование **(Применимо только в ручном режиме, аналитически)**
- 5.19 Нефункциональное тестирование **(Применимо только в ручном режиме, аналитически)**
- 5.20 Обеспечение безопасности при выпуске готовой к эксплуатации версии программного обеспечения
- 5.21 Безопасная поставка программного обеспечения пользователям
- 5.22 Обеспечение поддержки программного обеспечения при эксплуатации пользователями
- 5.23 Реагирование на информацию об уязвимостях **(п.п. 5.20 - 5.23 – орг. мера, реализация в рамках КСПД)**
- 5.24 Поиск уязвимостей в программном обеспечении при эксплуатации **(Применимо только в ручном режиме, аналитически)**
- 5.25 Обеспечение безопасности при выводе программного обеспечения из эксплуатации **(орг. мера, реализация в рамках КСПД)**